

Phase1

IEMS5718 Project

Hello, guestLogin

HomeElectronicsAccessoriesHeadphone

Home



Shopping List (0)

ElementsConsoleSourcesNetworkPerformanceMemoryApplicationSecurityLighthouseRecorderCookie-EditorComponentsProfiler

Filter

500 ms1,000 ms1,500 ms2,000 ms2,500 ms3,000 ms3,500 ms4,000 ms4,500 ms5,000 ms5,500 ms6,000 ms6,500 ms7,000 ms7,500 ms8,000 ms8,500 ms9,000 ms9,500 ms

Name

XHeadersPayloadPreviewResponseInitiatorTimingCookies

readability.js

▼General

products?catid=1

tools.js

default_thumb.jpg

FloatingActionButton.js

vendor.js

otherVendors.js

Request URL

Request Method

Status Code

Remote Address

Referrer Policy

https://s30.iems5718.iecuhk.cc/api/products?catid=1

GET

200 OK

127.0.0.1:7897

strict-origin-when-cross-origin

▼Response headers

☐ Raw

21 requests792 kB transfer

IEMS5718 Project

Hello, guestLogin

HomeElectronicsAccessoriesHeadphone

Shopping List (0)

ElementsConsoleSourcesNetworkPerformanceMemoryApplicationSecurityLighthouseRecorderCookie-EditorComponentsProfiler

Filter

500 ms1,000 ms1,500 ms2,000 ms2,500 ms3,000 ms3,500 ms4,000 ms4,500 ms5,000 ms5,500 ms6,000 ms6,500 ms7,000 ms7,500 ms8,000 ms8,500 ms9,000 ms9,500 ms

Name

XHeadersPayloadPreviewResponseInitiatorTimingCookies

s30.iems5718.iecuhk.cc

local-storage.js

util.js

fte-utils.js

express-fte.js

index-CIN_Cz8x.js

index-C9X4-Cay.css

express-utils.js

categories

csrf-token

user

sidePanelUtil.js

awesome.js

vite.svg

readability.js

products?catid=1

tools.js

default_thumb.jpg

FloatingActionButton.js

vendor.js

otherVendors.js

▼Response headers

☐ Raw

Access-Control-Allow-Credentials

Connection

Content-Length

Content-Security-Policy

Content-Type

Cross-Origin-Opener-Policy

Cross-Origin-Resource-Policy

Date

Etag

Origin-Agent-Cluster

Referrer-Policy

Server

Strict-Transport-Security

Vary

X-Content-Type-Options

X-Dns-Prefetch-Control

X-Download-Options

X-Frame-Options

true

keep-alive

425

default-src 'self';script-src 'self' https://www.paypal.com https://www.sandbox.paypal.com https://www.paypalobjects.com;style-src 'self' 'unsafe-inline';img-src 'self' data: /uploads/ https://www.paypal.com https://www.sandbox.paypal.com https://www.paypalobjects.com;connect-src 'self' https://www.paypal.com https://www.sandbox.paypal.com https://www.paypalobjects.com;frame-src 'self' https://www.paypal.com https://www.sandbox.paypal.com;base-uri 'self';font-src 'self' https: data:;form-action 'self';frame-ancestors 'self';object-src 'none';script-src-attr 'none';upgrade-insecure-requests

application/json; charset=utf-8

same-origin

same-origin

Mon, 11 May 2026 05:25:50 GMT

W/"1a9-y3r8aGv5dKB905fBkTjJCdoIF8"

71

no-referrer

nginx

max-age=31536000; includeSubDomains

Origin

nosniff

off

noopen

SAMEORIGIN

21 requests792 kB transfer

Items5718 Project

Hello, guestLogin

HomeElectronicsAccessoriesHeadphone

Shopping List (0)

ElementsConsoleSourcesNetworkPerformanceMemoryApplicationSecurityLighthouseRecorderCookie-EditorComponents *Profiler *

Filter

500 ms1,000 ms1,500 ms2,000 ms2,500 ms3,000 ms3,500 ms4,000 ms4,500 ms5,000 ms5,500 ms6,000 ms6,500 ms7,000 ms7,500 ms8,000 ms8,500 ms9,000 ms9,500

Name

s30.items5718.localhost.local-storage.jsutil.jsfte-utils.jsexpress-fte.jsindex-CIN_Cz8x.jsindex-C9X4-Cay.cssexpress-utlis.jscategoriescsrf-tokenuserpanelsidePanelUtil.jsproducts?catid=1vite.svgreadability.jsawesome.js tools.jsdefault_thumb.jpgFloatingActionButton.jsvendor.jsotherVendors.js

HeadersPayloadPreviewResponseInitiatorTimingCookies

Response headersRaw

HTTP/1.1 200 OK
Server: nginx
Date: Mon, 11 May 2026 05:46:51 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 425
Connection: keep-alive
Content-Security-Policy: default-src 'self';script-src 'self' https://www.paypal.com https://www.sandbox.paypal.com https://www.paypalobjects.com;style-src 'self' 'unsafe-inline';img-src 'self' data: uploads/ https://www.paypal.com https://www.sandbox.paypal.com https://www.paypalobjects.com;connect-src 'self' https://www.paypal.com https://www.sandbox.paypal.com https://www.paypalobjects.com;frame-src 'self' https://www.paypal.com https://www.sandbox.paypal.com;base-uri 'self';font-src 'self' https: data: form-action 'self';frame-ancestors 'self';object-src 'none';script-src-attr 'none';upgrade-insecure-requests
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Origin-Agent-Cluster: 71
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-DNS-Prefetch-Control: off
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-XSS-Protection: 0
Vary: Origin
Access-Control-Allow-Credentials: true
ETag: W/"1a9-y3r8Gv5dK89e5lF8kTjJc0iF8"

21 requests792 kB transferredRequest HeadersRaw

aws

Search

[Option+S]

Asia Pacific (Sydney)

XuChen (71602559779)

XuChen

EC2 > Instances > i-076b7e91a3735c301

EC2

Dashboard

AWS Global View

Events

Instances

Instance Types

Launch Templates

Spot Requests

Savings Plans

Reserved Instances

Dedicated Hosts

Capacity Reservations

Capacity Manager

Images

AMIs

AMI Catalog

Elastic Block Store

Volumes

Snapshots

Lifecycle Manager

Network & Security

Security Groups

Elastic IPs

Placement Groups

Instance summary for i-076b7e91a3735c301 (items5718-ec2)

Updated less than a minute ago

Instance ID

i-076b7e91a3735c301

IPv6 address

-

Hostname type

IP name: ip-172-31-26-209.ap-southeast-2.compute.internal

Answer private resource DNS name

IPv4 (A)

Auto-assigned IP address

-

IAM role

-

IMDSv2

Optional
EC2 recommends setting IMDSv2 to required | Learn more

Operator

-

Public IPv4 address

54.79.184.85 | open address

Instance state

Running

Private IP DNS name (IPv4 only)

ip-172-31-26-209.ap-southeast-2.compute.internal

Instance type

t3.micro

VPC ID

vpc-01e7331c3e5a17437

Subnet ID

subnet-06a2a239c013a7455

Instance ARN

arn:aws:ec2:ap-southeast-2:71602559779:instance/i-076b7e91a3735c301

Private IPv4 addresses

172.31.26.209

Public DNS

ec2-54-79-184-85.ap-southeast-2.compute.amazonaws.com | open address

Elastic IP addresses

54.79.184.85 [Public IP]

AWS Compute Optimizer finding

Opt-in to AWS Compute Optimizer for recommendations. | Learn more

Auto Scaling Group name

-

Managed

false

CloudShellFeedbackConsole Mobile App

© 2026, Amazon Web Services, Inc. or its affiliates. PrivacyTermsCookie preferences

The screenshot shows the AWS Management Console for an EC2 instance. The left sidebar contains navigation links for Dashboard, AWS Global View, Events, Instances, Instance Types, Launch Templates, Spot Requests, Savings Plans, Reserved Instances, Dedicated Hosts, Capacity Reservations, Capacity Manager, Images, AMIs, AMI Catalog, Elastic Block Store, Volumes, Snapshots, Lifecycle Manager, Network & Security, Security Groups, Elastic IPs, Placement Groups, and Key Pairs. The main content area is titled 'Security' and includes sections for Security details, Inbound rules, and Outbound rules. The Security details section shows the IAM role as '-', the Owner ID as '716025599779', and the Launch time as 'Sat Feb 07 2026 12:07:24 GMT+0800 (China Standard Time)'. The Security groups section shows a single group 'sg-05986d31309b297a9 (launch-wizard-1)'. The Inbound rules section shows three rules: 'sgr-03d0c9fb8745b6722' (port 443, TCP, 0.0.0.0/0), 'sgr-0b59f9e4c2ba0c431' (port 22, TCP, 0.0.0.0/0), and 'sgr-023094596bced64c8' (port 80, TCP, 0.0.0.0/0). The Outbound rules section shows one rule 'sgr-00657958955a1ee33' (All ports, All protocols, 0.0.0.0/0).

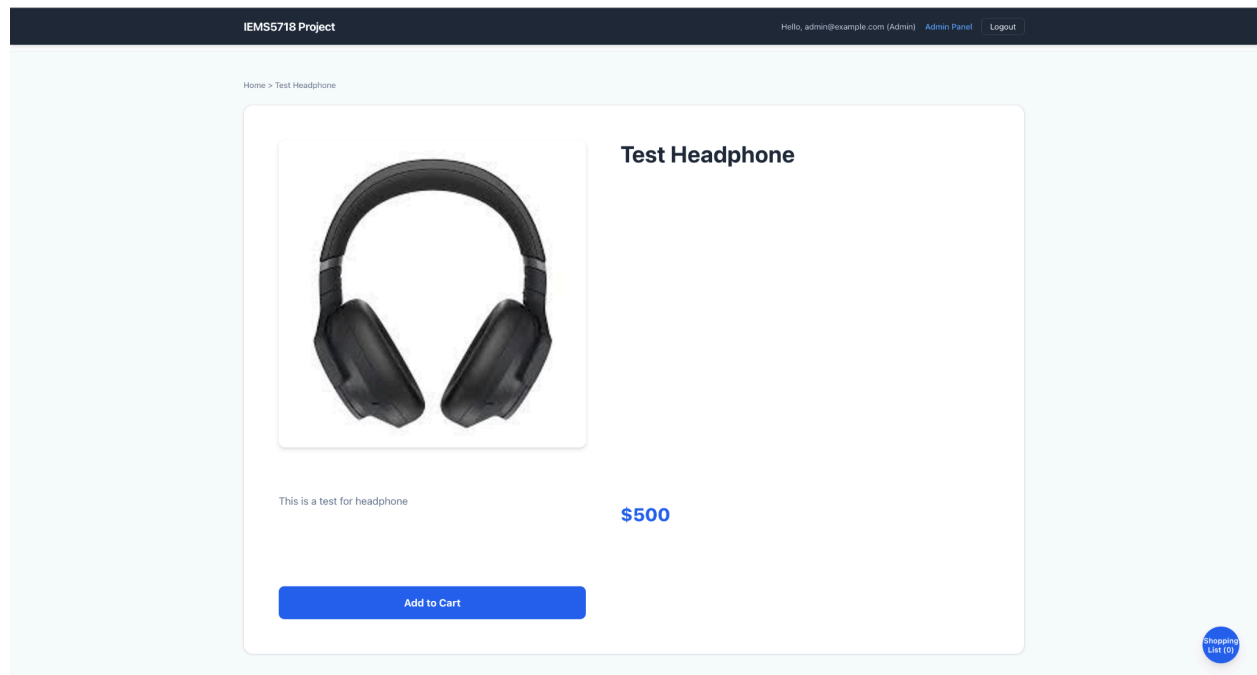
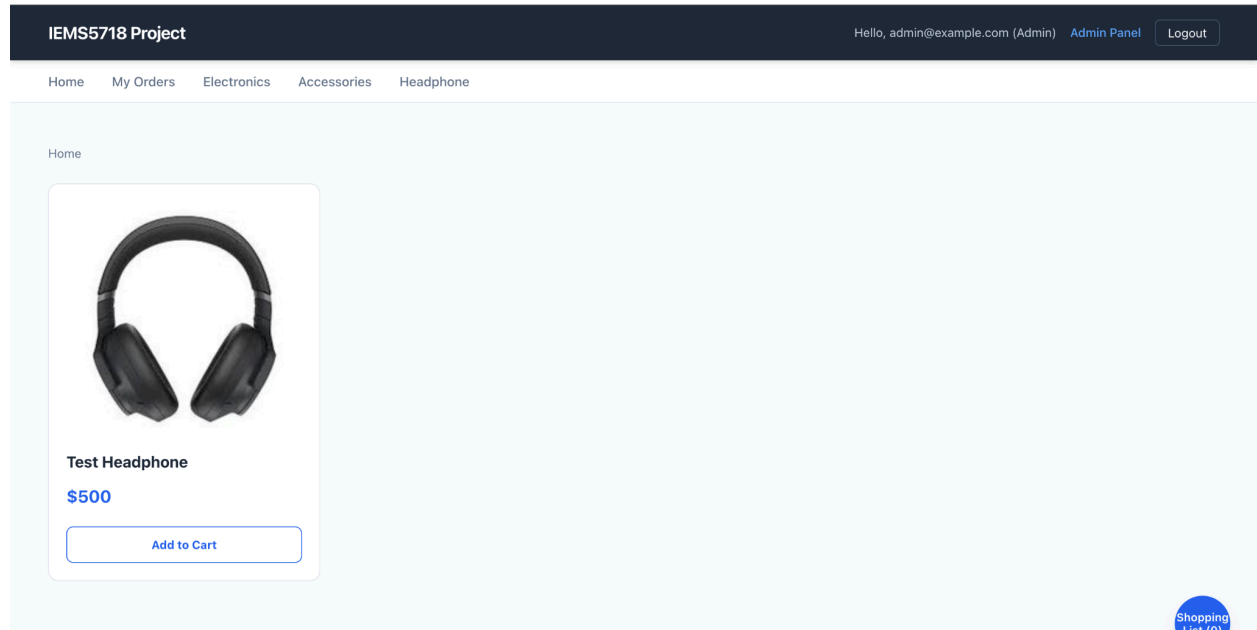
The screenshot shows the AWS Management Console for a VPC. The left sidebar contains navigation links for VPC dashboard, AWS Global View, Filter by VPC, Virtual private cloud, Your VPCs, Subnets, Route tables, Internet gateways, Egress-only internet gateways, DHCP option sets, Elastic IPs, Managed prefix lists, NAT gateways, Peering connections, Route servers, Security, Network ACLs, Security groups, PrivateLink and Lattice, Getting started, Endpoints, Endpoint services, and Service networks. The main content area is titled 'VPC dashboard' and includes sections for Details, Resource map, and Integrations. The Details section shows the VPC ID as 'vpc-01e7331c3e5a17437', the State as 'Available', the DNS resolution as 'Enabled', the Main network ACL as 'acl-054ff3af25656f404', the IPv6 CIDR as '172.31.0.0/16', and the Encryption control ID as '-'. The Resource map section shows a diagram of the VPC with three subnets (ap-southeast-2a, ap-southeast-2b, ap-southeast-2c) and one route table (rtb-09c6c5f2972dbe9c1).

1D. Web Server Architecture (Nginx + Node + DB)

Nginx listens on 443 and serves the frontend static files from `/var/www/html`. Nginx reverse proxies `/api/*` to the Node/Express backend on `http://localhost:3000`, reverse proxies `/admin/*` to the backend admin panel (protected by admin session), and proxies `/uploads/*` to the backend static product images. The Node.js backend provides REST APIs, authentication sessions, CSRF protection, PayPal integration, and serves admin panel files. SQLite stores users, categories, products, and order/payment records. PM2 manages the backend process for reliability and restarts.

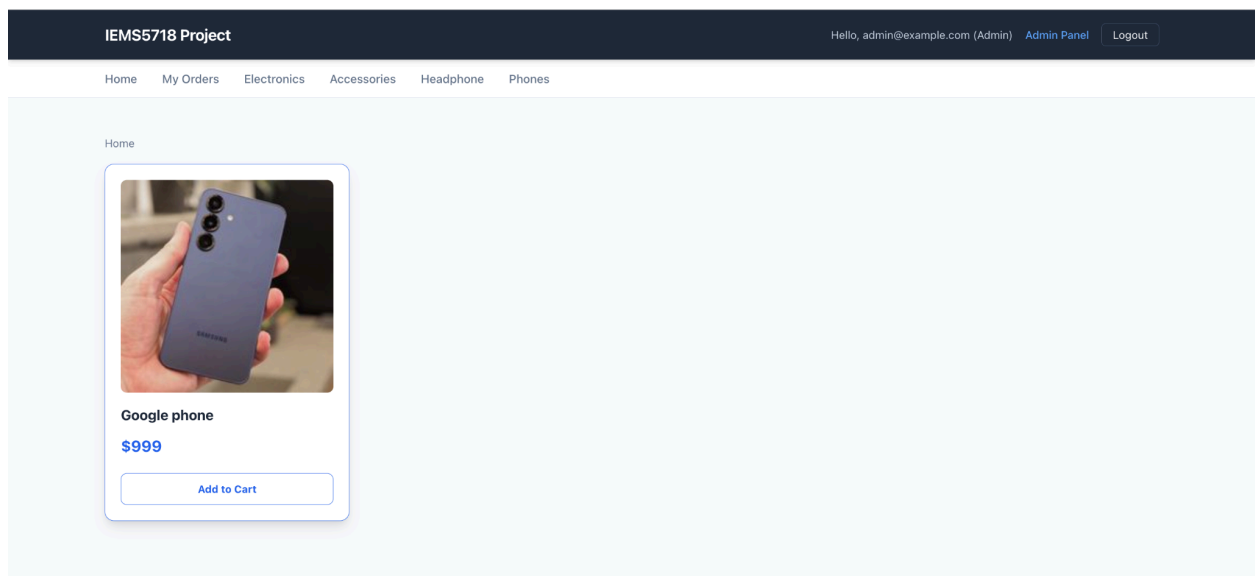
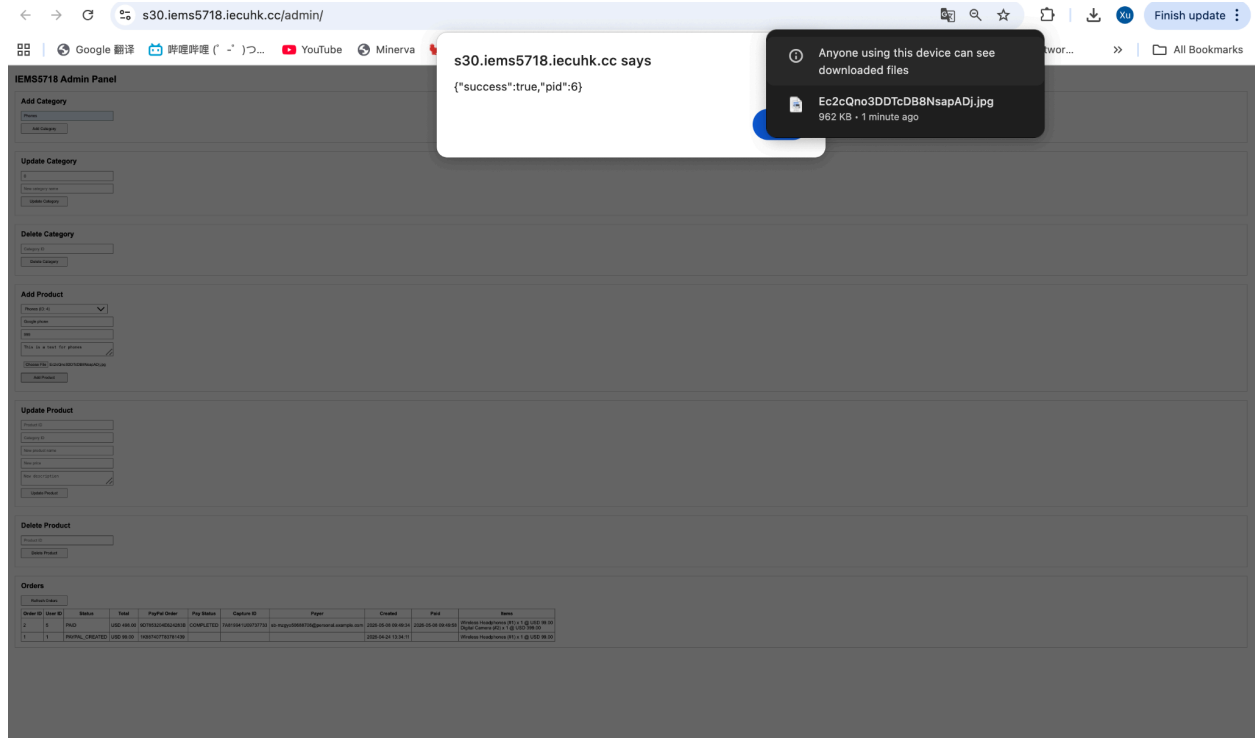
Phase2

2A



The frontend is a client-side rendered single-page application built with React. It fetches data from backend REST APIs such as `/api/categories`, `/api/products`, and `/api/products/:pid`, and updates UI state dynamically without full page reload.

2B



IEMS5718 Project

Hello, admin@example.com (Admin)Admin PanelLogout

[Home](#)[My Orders](#)[Electronics](#)[Accessories](#)[Headphone](#)[Phones](#)

Home > Google phone



Google phone

This is a test for phones

\$999

Add to Cart

Shopping List (0)

Logout

IEMS5718 Project

Hello, guestLogin

[Home](#)[Electronics](#)[Accessories](#)[Headphone](#)[Phones](#)

Home



Wireless Headphones
\$99

Add to Cart

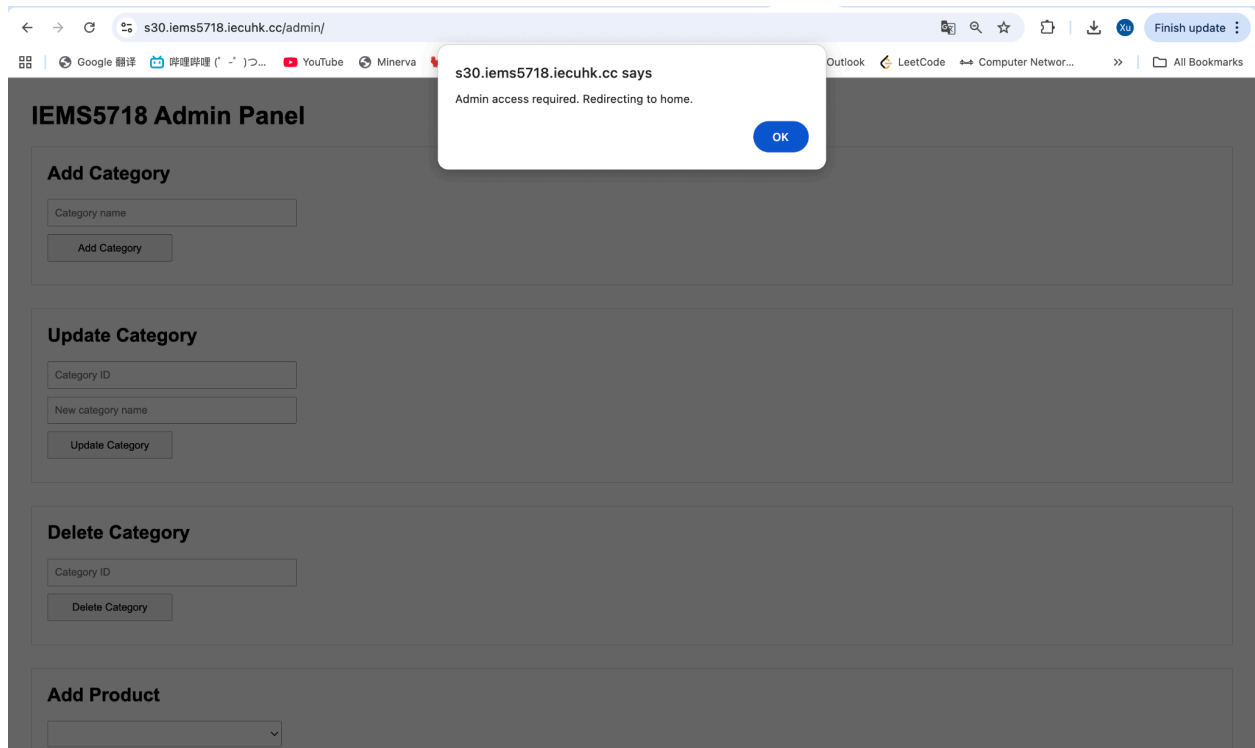


Digital Camera
\$399

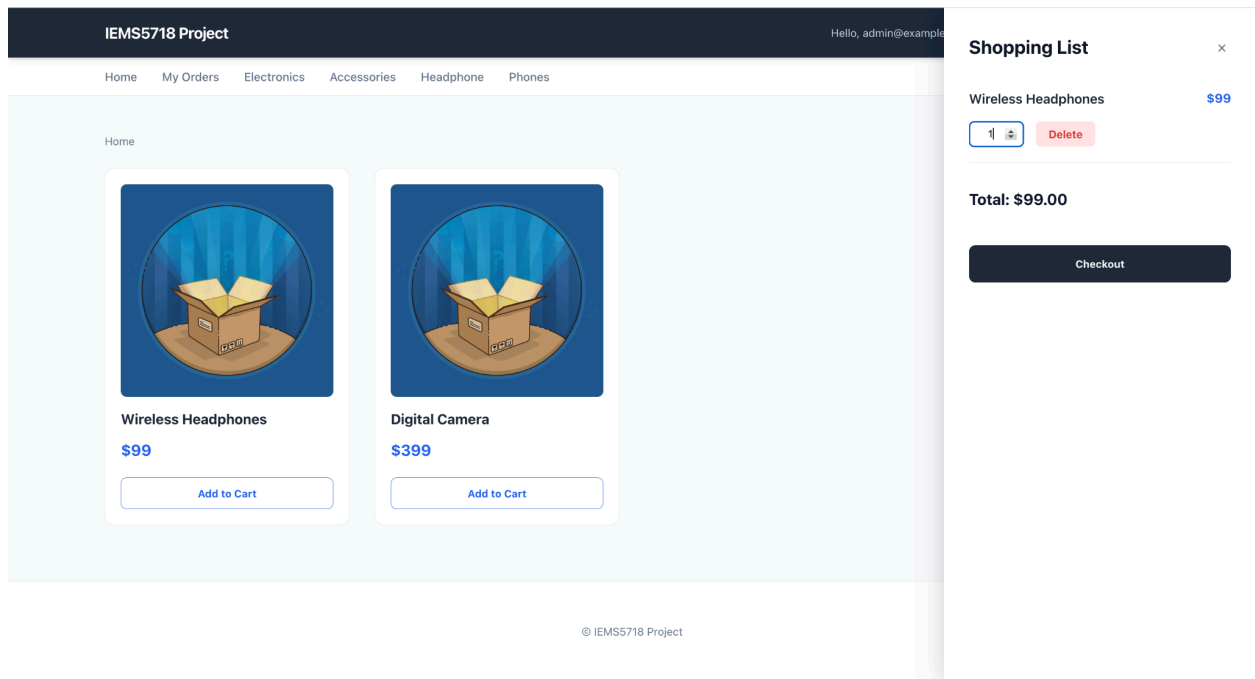
Add to Cart

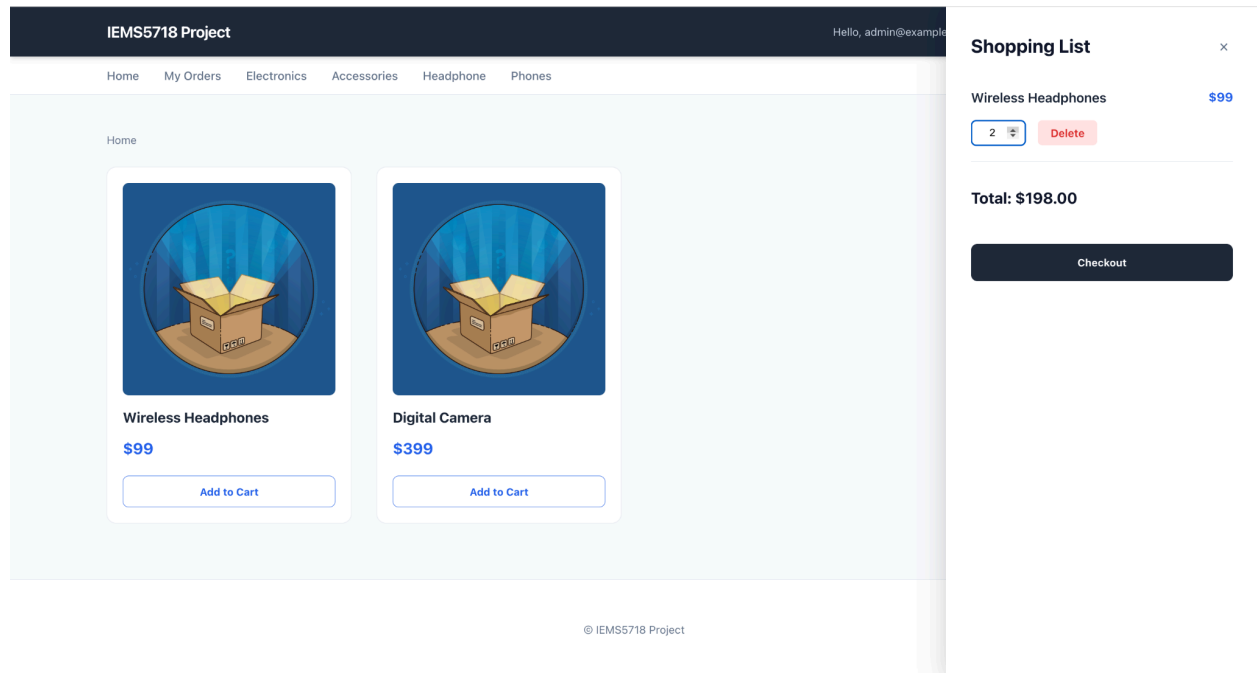
© IEMS5718 Project

Shopping List (0)

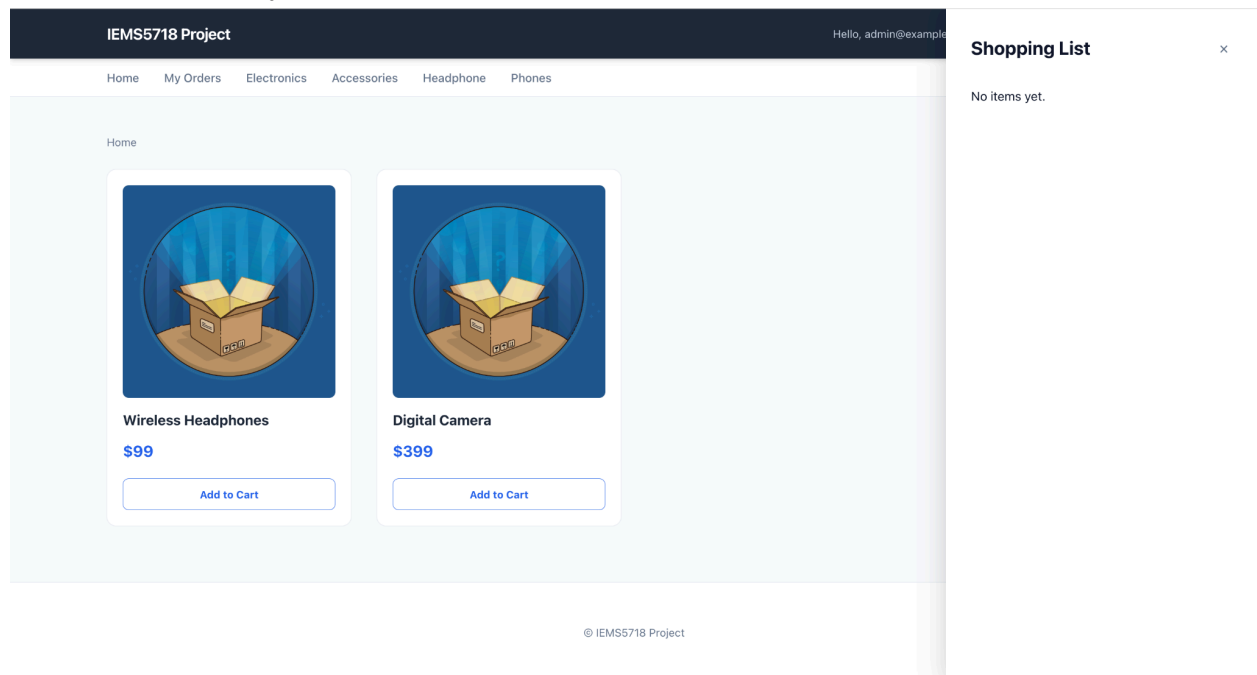


Phase3





After set to 0 quantity



Phase4

XSS mitigation is applied via server-side input sanitization/escaping and safe DOM rendering patterns in the admin panel. CSRF protection is enforced by issuing tokens from `/api/csrf-token` and requiring `x-csrf-token` for state-changing requests. SQL injection is mitigated by using

parameterized queries for SQLite. Session fixation is mitigated by regenerating the session after successful login. Passwords are stored as bcrypt hashes. HTTP security headers are set using Helmet, including CSP; CSP is configured to allow PayPal domains required for checkout rendering. Access control is enforced via isAdmin for admin routes and isLoggedIn for member-only endpoints. In production, cookies are set with secure and httpOnly attributes.

IEMS5718 Project

Hello, guestLogin

[Home](#)[Electronics](#)[Accessories](#)[Headphone](#)[Phones](#)

Login

Login

Login

Don't have an account? [Register here](#)

Shopping List (0)

IEMS5718 Project

Hello, guestLogin

[Home](#)[Electronics](#)[Accessories](#)[Headphone](#)[Phones](#)

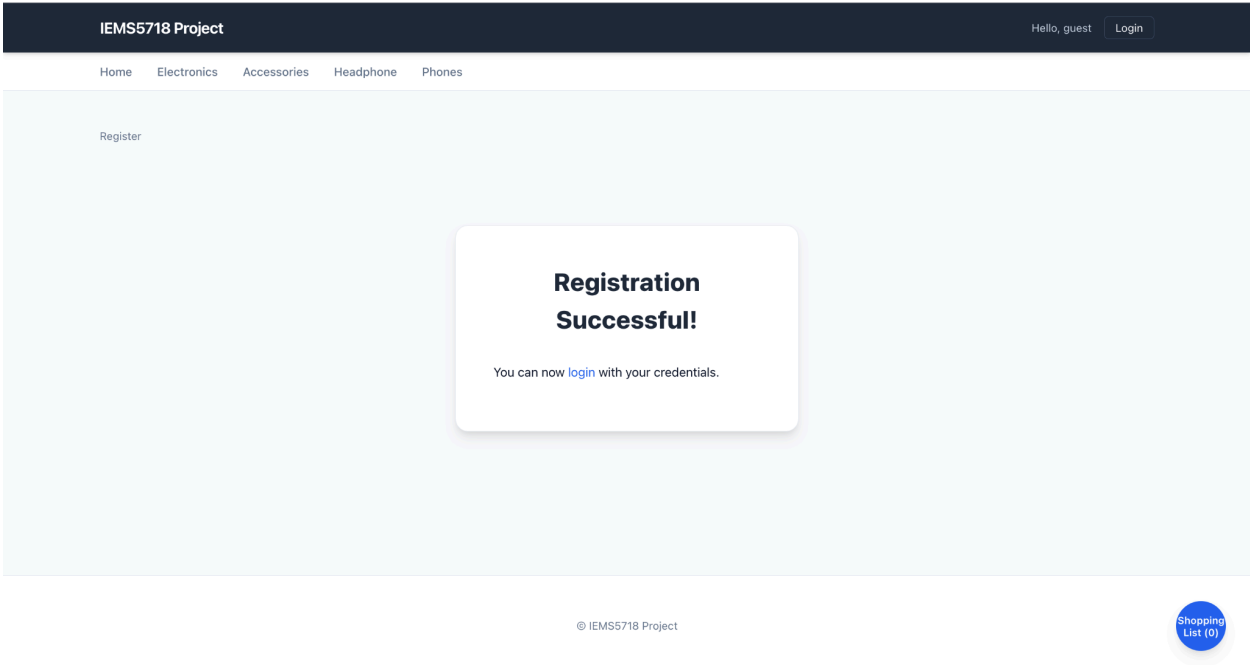
Register

Register

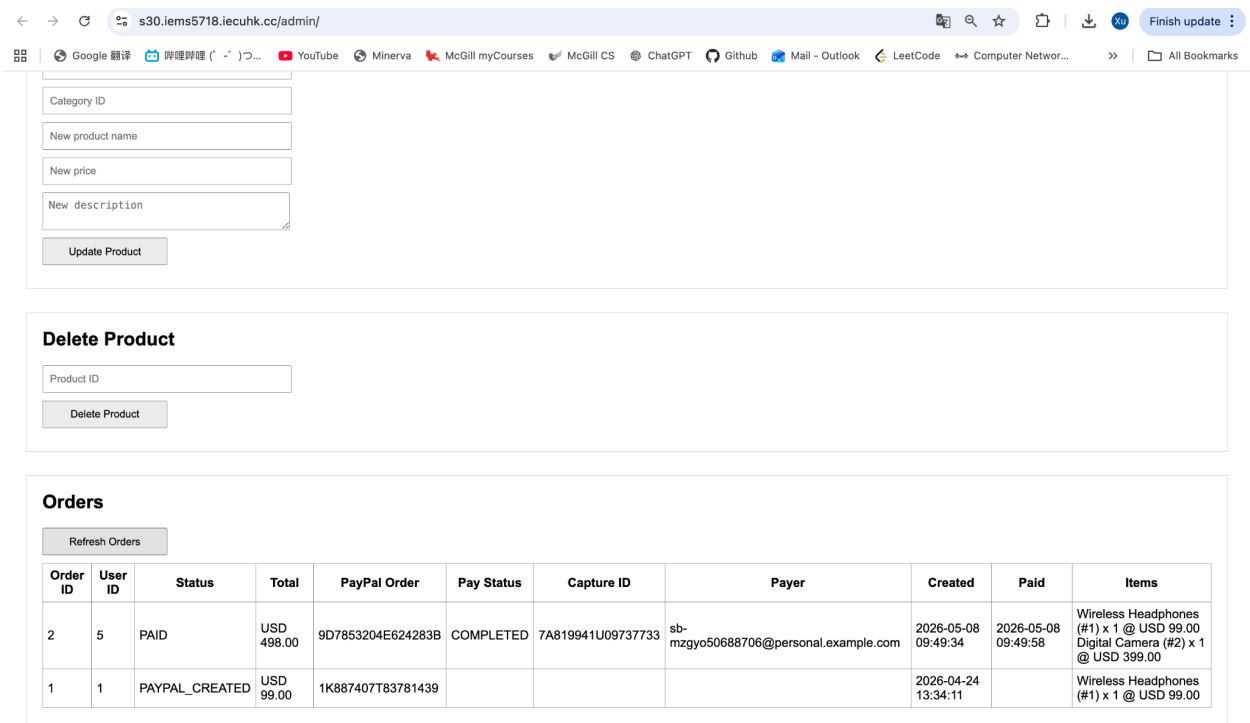
Register

Already have an account? [Login here](#)

Shopping List (0)



Phase5



IEMS5718 Project

Hello, admin@example.com

Home

My Orders

Electronics

Accessories

Headphone

Phones

Home



Test Headphone

\$500

Add to Cart

Shopping List

X

Digital Camera

\$399

1

Delete

Google phone

\$999

1

Delete

Test Headphone

\$500

1

Delete

Total: \$1898.00

Checkout

© IEMS5718 Project

IEMS5718 Project

Hello, admin@example.com

Home

My Orders

Electronics

Accessories

Headphone

Phones

Home



Test Headphone

\$500

Add to Cart

Shopping List

X

Digital Camera

\$399

1

Delete

Google phone

\$999

1

Delete

Test Headphone

\$500

1

Delete

Total: \$1898.00

PayPal

借记卡或信用卡

技术支持提供方: PayPal

© IEMS5718 Project

有PayPal账户?

或

使用借记卡或信用卡付款

您的详细财务信息不会透露给卖家。

国家/地区

中国

电子邮件

barychen2107@gmail.com

电话类型

手机

电话号码

+86



卡号

有效期至

CSC



账单地址

名

姓

省/直辖市

市

地址第1行

地址第2行 (选填)

邮政编码

☒ 收货地址与账单地址相同

保存信息并创建PayPal账户



放心购物 收款更方便 优惠更多 大额转账

创建密码


PayPal更安全、更便捷的
付款方式
无论您在何处购物，我们都会帮助您确保财
务信息的安全。

New price

New description

Update Product

Delete Product

Product ID

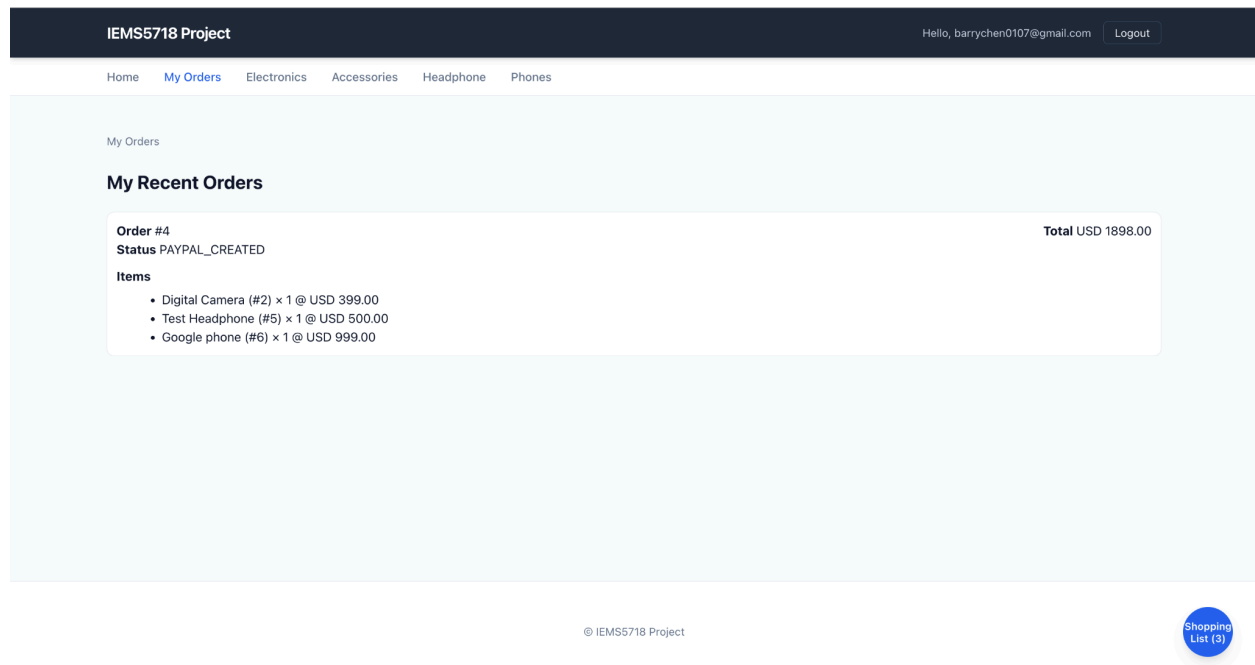
Delete Product

Orders

Refresh Orders

Order ID	User ID	Status	Total	PayPal Order	Pay Status	Capture ID	Payer	Created	Paid	Items
3	1	PAYPAL_CREATED	USD 1898.00	3H8480812R720420H				2026-05-11 06:10:08		Digital Camera (#2) x 1 @ USD 399.00 Test Headphone (#5) x 1 @ USD 500.00 Google phone (#6) x 1 @ USD 999.00
2	5	PAID	USD 498.00	9D7853204E624283B	COMPLETED	7A819941U09737733	sb-mzgyo50688706@personal.example.com	2026-05-08 09:49:34	2026-05-08 09:49:58	Wireless Headphones (#1) x 1 @ USD 99.00 Digital Camera (#2) x 1 @ USD 399.00
1	1	PAYPAL_CREATED	USD 99.00	1K887407T83781439				2026-04-24 13:34:11		Wireless Headphones (#1) x 1 @ USD 99.00

Personal account



Phase6

I implemented the following extensions/improvements: PayPal webhook signature verification, member order history page (recent 5 orders), admin order tracking panel with item list and payment information, and Nginx routing for /uploads/ to ensure product images load correctly in production. Please see more details in README.md

Phase7

Key security fixes include using Helmet security headers (CSP and related headers), enforcing CSRF tokens for mutation endpoints, validating/sanitizing user inputs, using parameterized SQL queries, regenerating sessions after login to prevent session fixation, enforcing admin-only access for admin panel and APIs, and verifying PayPal webhook signatures with idempotent payment recording.

Appendix

Admin account:

Admin URL: <https://s30.iems5718.iecuhk.cc/admin/>

Email: admin@example.com

Password: admin123

Key URLs:

Main site: <https://s30.iems5718.iecuhk.cc/>

Admin: <https://s30.iems5718.iecuhk.cc/admin/>

Categories API: <https://s30.iems5718.iecuhk.cc/api/categories>

Products API example: <https://s30.iems5718.iecuhk.cc/api/products?catid=1>

My Orders: login on main site, then click "My Orders"